

Cyber Security

**Phishing, Spoofingsniffing,
DoSDDoS**

By
Dr. Mudassar Raza
Professor
Department of Computer Science
Namal University Mianwali



https://techgirls.ece.vt.edu/slides/introduction_to_cybersecurity.html#39

What is Phishing?

What Is Phishing?

- Phishing email messages, websites, and phone calls are designed to steal money or sensitive information.
- Cybercriminals can do this by installing malicious software on your computer, tricking you into giving them sensitive information, or outright stealing personal information off of your computer.

•

Types of Phishing Attacks

- **Social Engineering**
- **Link Manipulation**
- **Spear phishing**
- **Clone phishing**
- **Voice Phishing**

Types of Phishing Attacks

Social Engineering - On your Facebook profile or LinkedIn profile, you can find: Name, Date of Birth, Location, Workplace, Interests, Hobbies, Skills, your Relationship Status, Telephone Number, Email Address and Favorite Food. This is everything a Cybercriminal needs in order to fool you into thinking that the message or email is legitimate.

Link Manipulation - Most methods of phishing use some form of deception designed to make a link in an email appear to belong to the spoofed organization or person. Misspelled URLs or the use of subdomains are common tricks used by phishers. Many email clients or web browsers will show previews of where a link will take the user in the bottom left of the screen or while hovering the mouse cursor over a link.

Types of Phishing Attacks

Spear phishing - Phishing attempts directed at specific individuals or companies have been termed spear phishing. Attackers may gather personal information (social engineering) about their targets to increase their probability of success. This technique is, by far, the most successful on the internet today, accounting for 91% of attacks.

Clone phishing - A type of phishing attack whereby a legitimate, and previously delivered email containing an attachment or link has had its content and recipient address(es) taken and used to create an almost identical or cloned email. The attachment or link within the email is replaced with a malicious version and then sent from an email address spoofed to appear to come from the original sender.

Types of Phishing Attacks

Voice Phishing - Voice phishing is the criminal practice of using social engineering over the telephone system to gain access to personal and financial information from the public for the purpose of financial reward. Sometimes referred to as 'vishing', Voice phishing is typically used to steal credit card numbers or other information used in identity theft schemes from individuals.

Examples of Phishing Attacks

Spear Phishing



Examples of Phishing Attacks

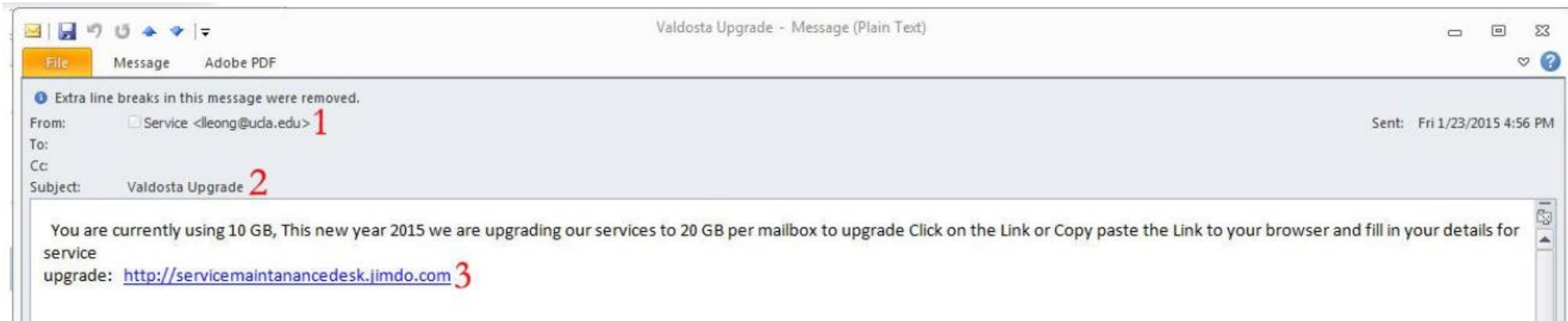
Spear Phishing



1. The first question you have to ask is, “**Do I know this person?**” or “**Am I expecting an email from the person?**” If you answered no to either question, you must take a harder look at other aspects of the email
2. A large amount of phishing emails will blank out the To: or Cc: fields so that you cannot see that this is a mass email to a large group of people.
3. Phishing emails will often come with subjects that are in all capitals or have multiple exclamation marks in order for you to think that this email is important or that you should take the recommended action within the email.
4. This is a targeted email (Spear Phishing) to VSU, so more than likely, this was sent to everyone at VSU that the sender had in their address book.
5. **Hovering your mouse over the link**, you can see that this is not taking you to a valdosta.edu address, but rather to an external site. This site would either prompt you for a password, then steal that password, or would download a malicious file infecting your computer.

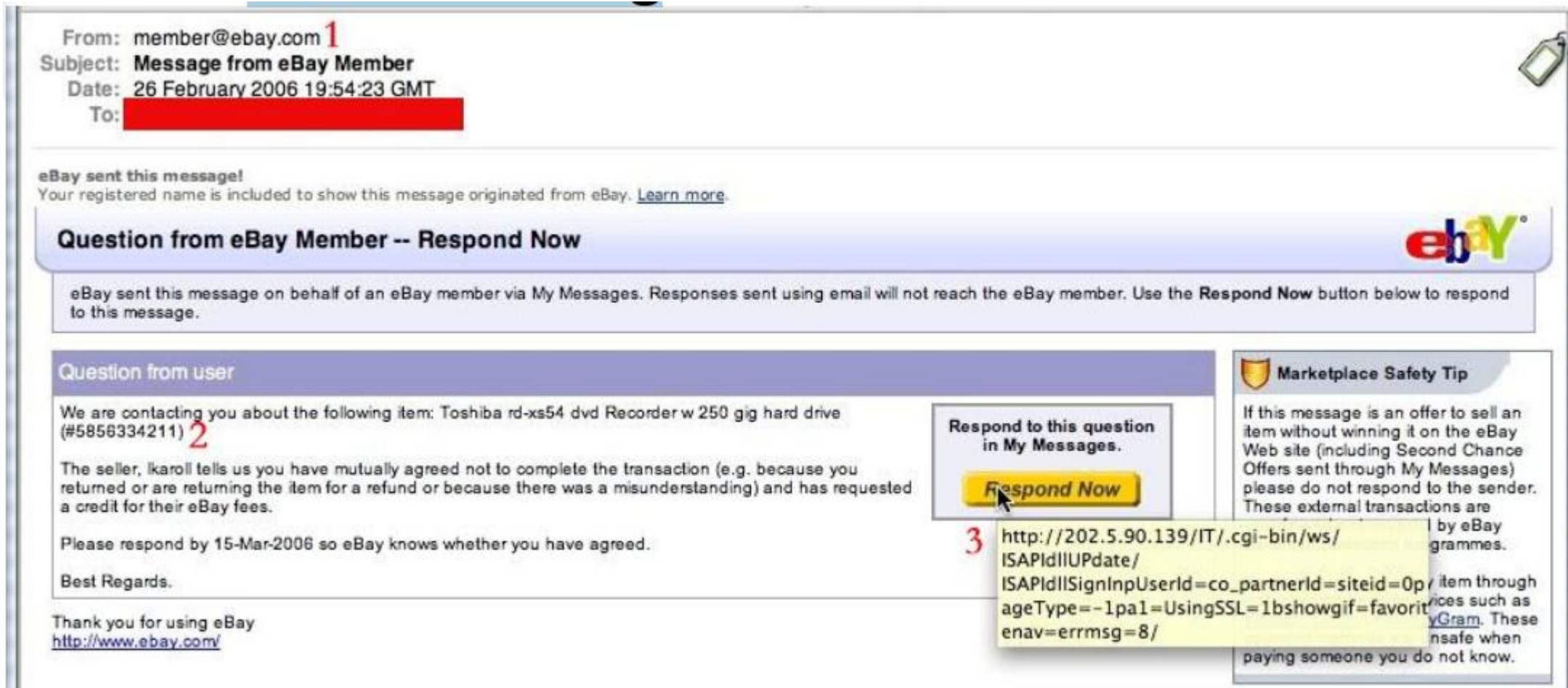
Examples of Phishing Attacks

Spear Phishing



Examples of Phishing Attacks

Clone Phishing



Examples of Phishing Attacks

Clone Phishing

1. These emails are harder to spot because they look exactly like legitimate emails you would normally receive. The first cue that something is not right with this email is the sender. It is a generic address, member@ebay.com. You would never see this from a legitimate email, you would see the username of the buyer/seller; e.g.; valdostarocks@ebay.com
2. The question you have to ask yourself is did I buy anything from ebay recently, and if I did, is this what I purchased? If no to these questions, then you more than likely have a phishing email.
3. The last piece is the most critical in seeing if the email is in fact a phishing email. If you **hover your mouse** over the button it is wanting you to press, you see that this is not taking you to an ebay.com site, but rather an external site that will more than likely try to steal your ebay credentials.

Examples of Phishing Attacks

Link manipulation

From [redacted] [redacted]@valdosta.edu>¹
Date: Wednesday, January 28, 2015 at 2:09 PM²
Subject: UPDATE YOUR E-MAIL ACCOUNT!!³

UPDATE YOUR E-MAIL ACCOUNT!!³

Your email account will soon be suspended (<http://tuto-web.fr/wp-addon/notice/> Click to follow link nce).

To update your email account, please [CLICK HERE](#) immediately for reactivation of your mail account. This mail is sent to you from our secured CSSD service Center. Please follow instruction on this message and your account will be updated within 24 hours.

We sincerely apologize for the unusual problem.⁴

Thank you for using our online services.

Web-Administrator.⁵

Examples of Phishing Attacks

Link manipulation

1. This is actually from a valdosta.edu address, so first you have to ask whether or not this is from someone you know or someone that would be emailing you about your email account. Remember that **only members of I.T. will email you about your accounts.**
2. One again, cybercriminals will use a subject line trying to get your attention, often using all caps and multiple exclamation marks. **A legitimate email from I.T. will not do this.**
3. The To: and Cc: lines are not shown so that you can't tell this is a mass email targeting multiple individuals.
4. **Hovering your mouse over the link**, you can see that this is not a legitimate valdosta.edu link, but an external one designed to steal your information or install malicious software.
5. The signature often will end in a generic sign off as to not arouse suspicion as to the sender.

Examples of Phishing Attacks

Social Engineering

4/8



Jane Smith

Hey! Thanks for adding me as a contact!

4/13



Jane Smith

Hey! I noticed you like Acme Sneakers. Check out this site—they have awesome prices!

Acme Sneakers for Cheap

<http://acmesneakers.premiumisp.net/store/a47ac0/index.html>
Chek out these awwsome deals on Acme Sneakers! Half price!
Buy them while they last!



Kathie Jones wrote at 12:59pm

Hey check this out!

I just got myself a free \$500 gift card to macys

I'm gonna have so much fun!

You all should get one yourself

check out the url below!

<http://2url.org/?67562>

Examples of Phishing Attacks

Social Engineering

The example on the left is a targeted social engineering attack. Cybercriminals scan your profile for your likes and then send you a crafted message over social media trying to trick you into clicking the link, which would then steal your social media login and take over your profile sending out more phishing attacks to your friends/contact list.

The one on the right is an example of a mass phishing attack through social media. No doubt many of you have seen these in Facebook, from random people in messages, or from your friends through their timelines. Upon clicking the link, it would prompt you to log in again, but this time to a fake Facebook page, and steal your log in information and take over your profile sending out the same or another mass phishing attack to your friends and contacts.

Emotional Triggers Exploited by Phishing

- Greed
- Fear
- Heroism
- Desire to be Liked
- Authority

Greed

Date: Mon, 5 Jan 2004 09:30:13
From: chika_williams@tiscali.co.uk
To: gullible@yahoo.com
Subject: URGENT

**RE: URGENT REQUEST FOR YOUR UNALLOYED CO-OPERATION TO
TRANSFER (US\$20.4 MILLION U.S. DOLLARS ONLY) INTO YOUR PRIVATE
OR COMPANY'S ACCOUNT**

Fear/Authority

Dear Wamu Customer,

We regret to inform you that we had to lock your Wamu account access because we have reasons to believe that it may have been compromised by outside parties. In order to protect your sensitive information, we temporarily suspended your account access.

[Click here](#) to verify and reactivate your account access by completing the secure form that will appear.

This is a security measure that will ensure that you are the only person with access to the account. Thank you for your time and consideration in this matter.

Please do not reply to this message.
For any inquiries, contact Customer Service.

Document Reference: (87051203).

**© Copyright 1998-2006, Washington Mutual, Inc.
All rights reserved.**

Heroism/Desire to be Liked



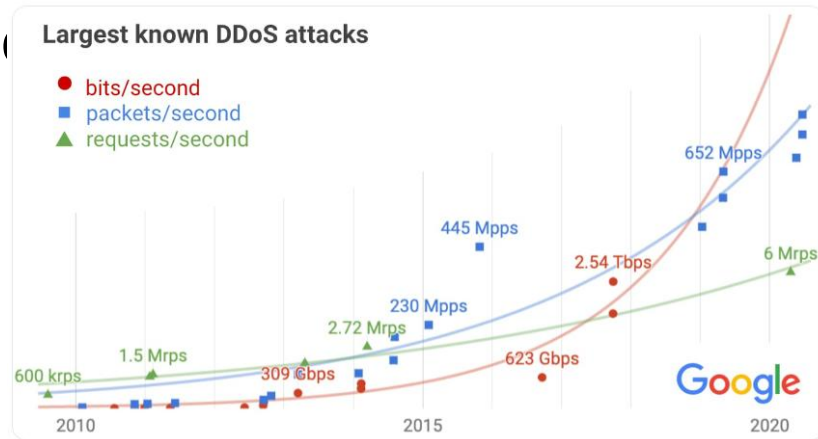
Tips to protect yourself from Phishing emails

- I.T. will **NEVER** ask for your password over email. Please be wary of any emails asking for passwords. **Never send passwords, bank account numbers, or other private information in an email.**
- Be cautious about opening attachments and downloading files from emails, regardless of who sent them. These files can contain viruses or other malware that can weaken your computer's security. If you are not expecting an email with an attachment from someone, such as a fax or a PDF, please **call** and ask them if they indeed sent the email. If not, let them know they are sending out Phishing emails and need to change their email password immediately.
- **Never** enter private or personal information into a popup window.
- If there is a link in an email, use your mouse to hover over that link to see if it is sending you to where it claims to be, this can thwart many phishing attempts.
- Look for '**https://**' and a **lock icon**  in the address bar before entering any private information on a website.
- Look for spelling and bad grammar. Cybercriminals are not known for their grammar and spelling. Professional companies or organizations usually have staff that will not allow a mass email like this to go out to its users. If you notice mistakes in an email, it might be a scam.

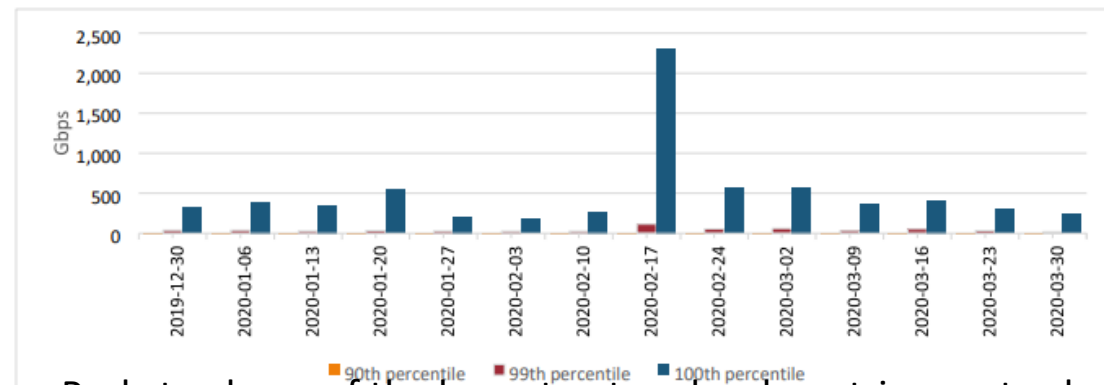
Denial of Service (DoS) and Distributed DoS (DDoS) Attacks

Denial of Service Attack (DoS)

- A Denial of Service (DoS) attack aims to render a server or a device unavailable to legitimate users by interrupting the device's normal services¹
- A Distributed DoS (DDoS) is a type of DoS that originates from multiple distributed sources (e.g., botnet DDoS attack), thus, amplifying the effect



Largest known DDoS attacks in Google Cloud between 2010 and 2020. [Figure taken from Google Cloud blogs. <https://tinyurl.com/bdzuupb6>]

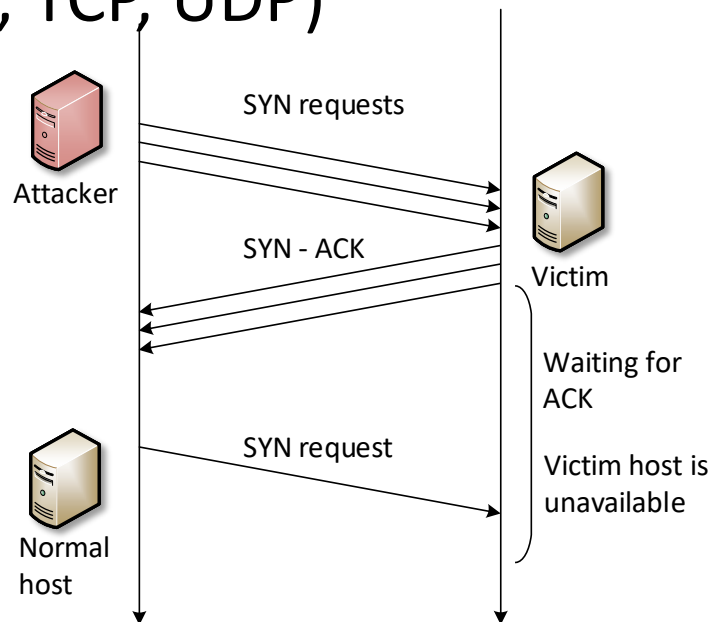


Packet volume of the largest network volumetric events observed by AWS in Q1 2020. [Figure taken from AWS Shield Report. <https://tinyurl.com/yd3ehx47>]

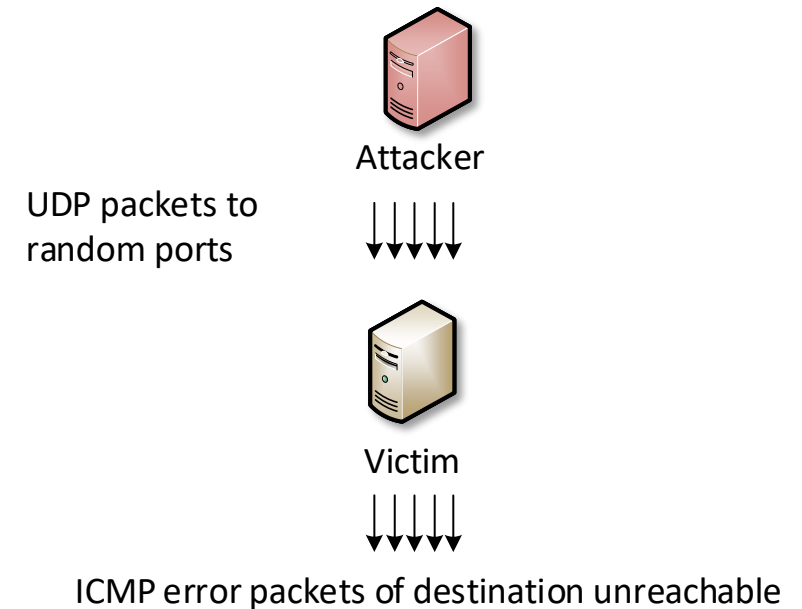
¹ Cloudflare, "What is a denial-of-service (DoS) attack?", [Online]. Available: <https://www.cloudflare.com/learning/ddos/glossary/denial-of-service/> By: Dr. Mudassar Raza

Types of DoS Attacks

- DoS attacks can be classified as **volumetric, reflected, and stealthy** DoS attacks
- Volumetric DoS attacks flood the target machine with traffic, depriving legitimate users from downloading the target's resources
- DoS attacks can be performed at various levels of the protocol stack (e.g., TCP, UDP)



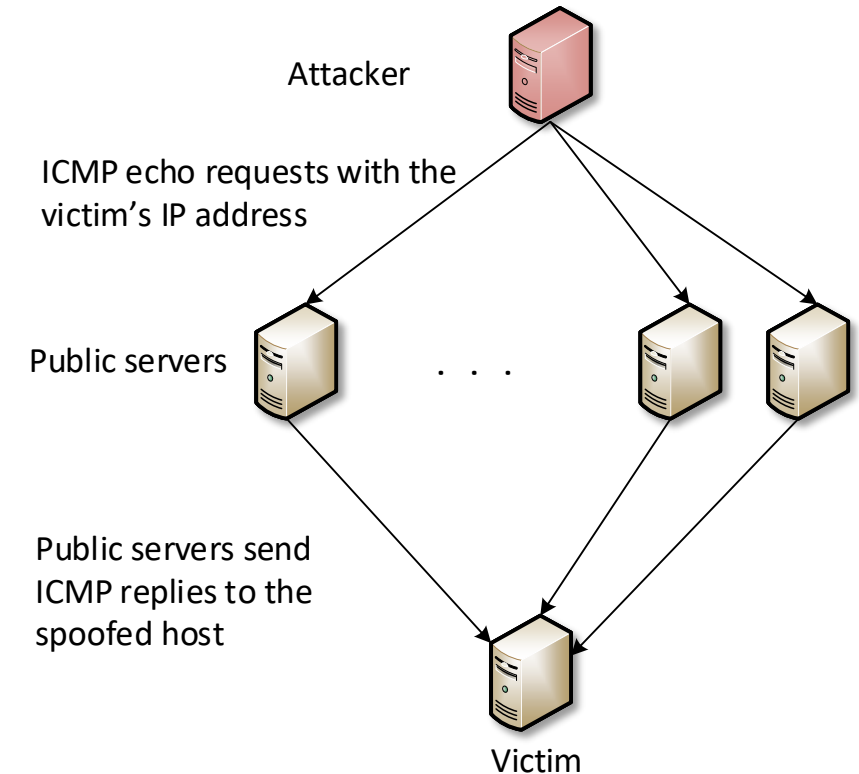
TCP SYN flood attack



UDP flood attack By: Dr. Mudassar Raza

Types of DoS Attacks

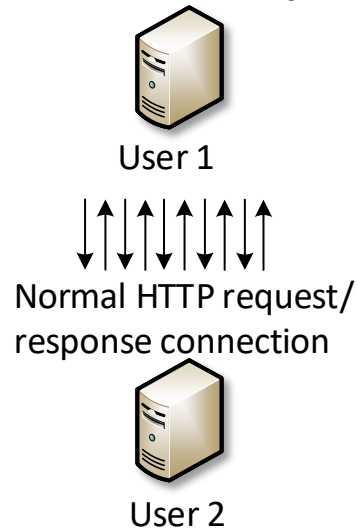
- Reflected DoS attacks (amplification attacks) make use of a third-party component to send the attack traffic to a victim, ultimately hiding the attacker's own identity
- In a reflected DoS attack
 - The attacker spoofs the source IP address of the target victim machine
 - The reflector sends response packets that overwhelm the victim
- *Smurf* reflected DoS attack uses ICMP echo requests and public servers to overwhelm a target victim



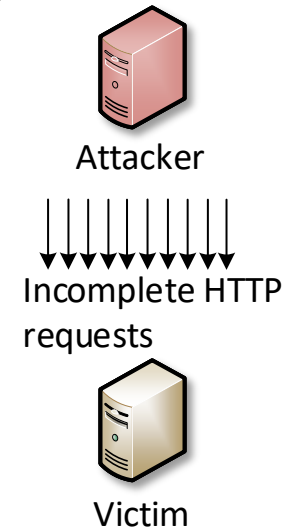
Smurf reflected DDoS attack

Types of DoS Attacks

- A stealthy DoS attack (slow DoS) use low bandwidth rates when targeting a victim
- *SlowLoris* attack establishes many connections to a target server and holds them as long as possible
- *SlowLoris* sporadically sends partial requests to keep the session active



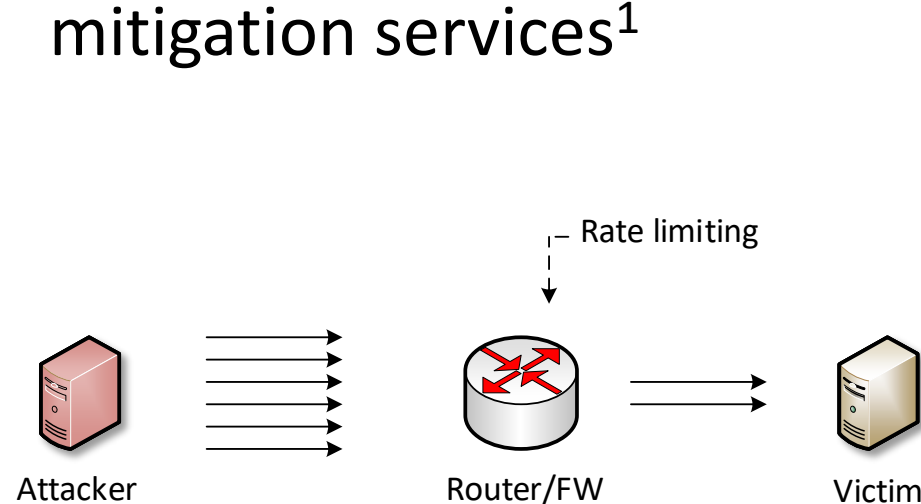
Normal connection: complete HTTP request/response connections



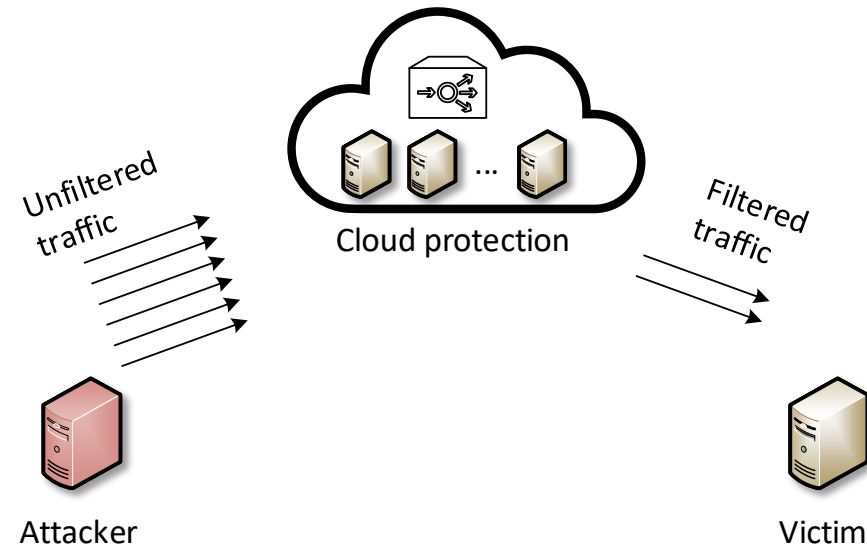
SlowLoris attack: incomplete HTTP requests

DoS Mitigation

- DoS mitigation refers to the process of successfully protecting a targeted server or network from a DoS attack
- Traditional DoS mitigation strategies include purchasing and maintaining expensive equipment
- Modern infrastructure relies on cloud providers to provide DoS mitigation services¹



Rate limiting against DoS attacks

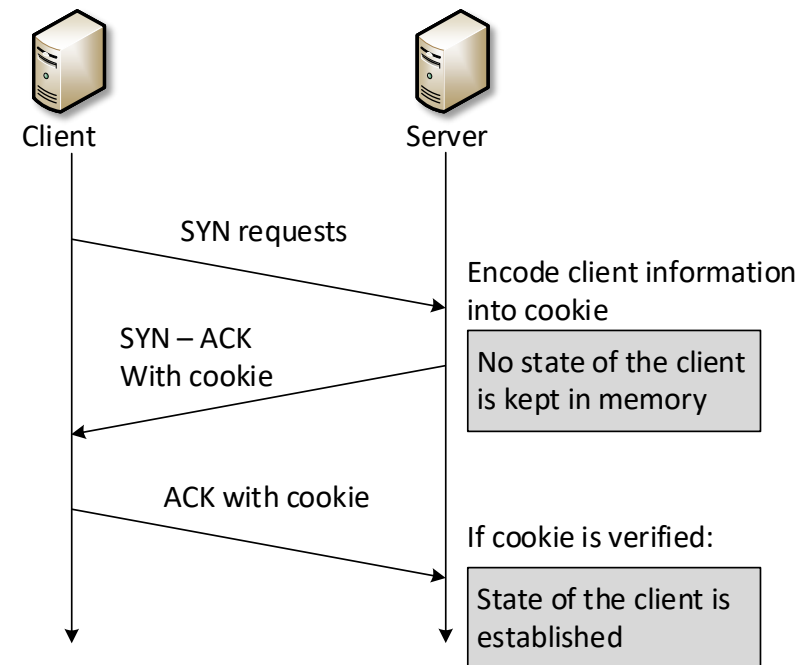
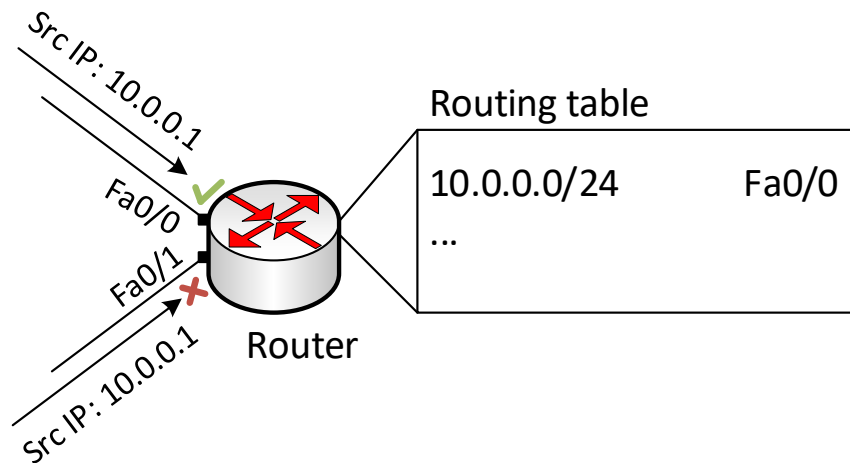


Cloud-based DoS protection

¹ Cloudflare, "What is DDoS mitigation?", [Online]. Available: <https://www.cloudflare.com/learning/ddos/ddos-mitigation/>

DoS Mitigation

- Additionally, operating systems provide some level against DoS attacks
 - In Linux, the following techniques are implemented:
 - Reverse path filtering: prevents IP spoofing associated with DoS attacks
 - SYN cookie: prevents against SYN flood attacks
 - Session's caching: allows for rapid recent TCP sessions to



Sniffers

What Is Sniffing?

Sniffers are a broad category that encompasses any utility that has the **ability to perform a packet-capturing function.**

- Is the act of viewing information as it flows over the network
- Can be performed with **hardware or software**
- Preys on vulnerable networks and protocols
 - Passwords (from email, the Web, SMB, FTP, SQL, or Telnet)
 - Email text

Law Enforcement and Sniffing

Lawful interception (LI) is defined as legally accessing communications and network data such as telephone calls or email messages.

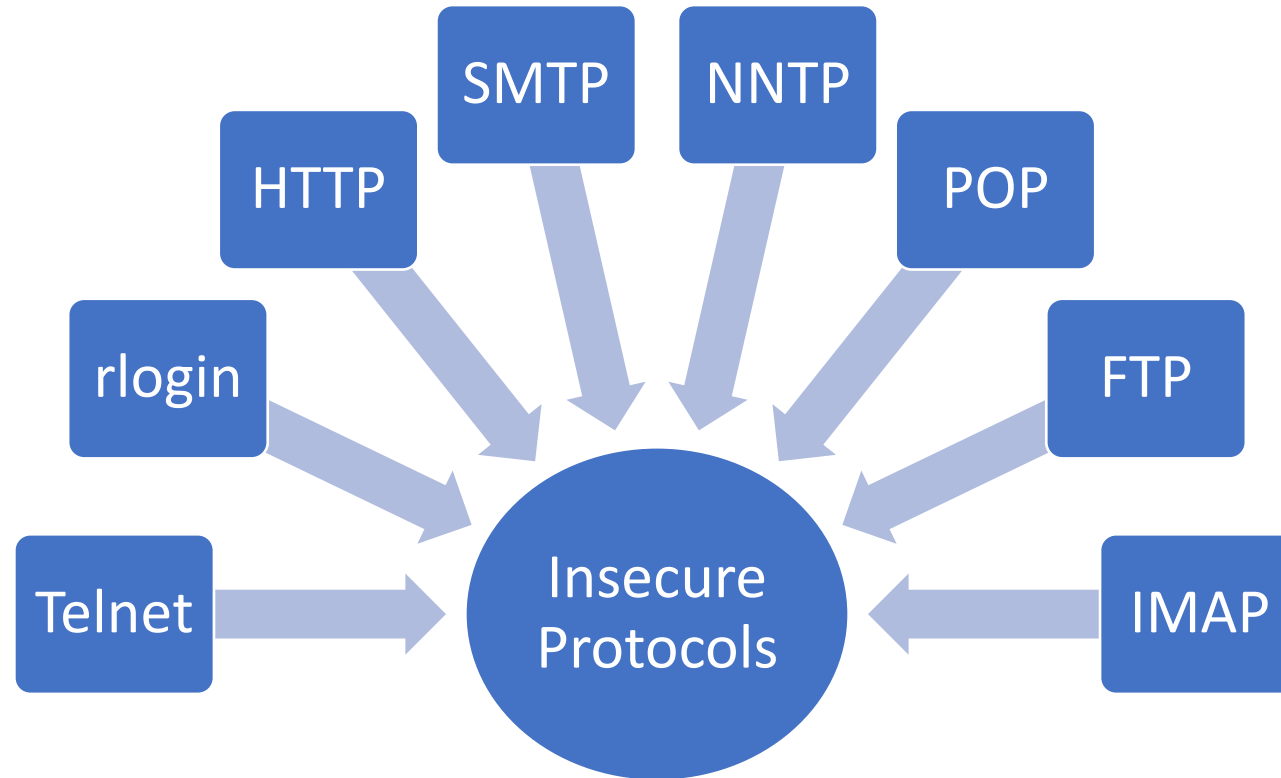
Lawful interception is legally sanctioned access to network data

Must have authority in pursuit of evidence or analysis

Regulated by the law

Sometimes called wiretapping

Vulnerable Protocols



How successful you are at the sniffing process depends on the relative and inherent insecurity of certain network protocols.

A Quick Overview

Packet sniffing, or **packet analysis**, is the process of capturing any data passed over the local network and looking for any information that may be useful.

- 1 Packet sniffing can capture any traffic flowing over a network.
- 2 Packet sniffers are commonly used for troubleshooting purposes.
- 3 Many tools are available to perform the process.
- 4 Passive form is just like eavesdropping on a conversation.

What's Required to Sniff?

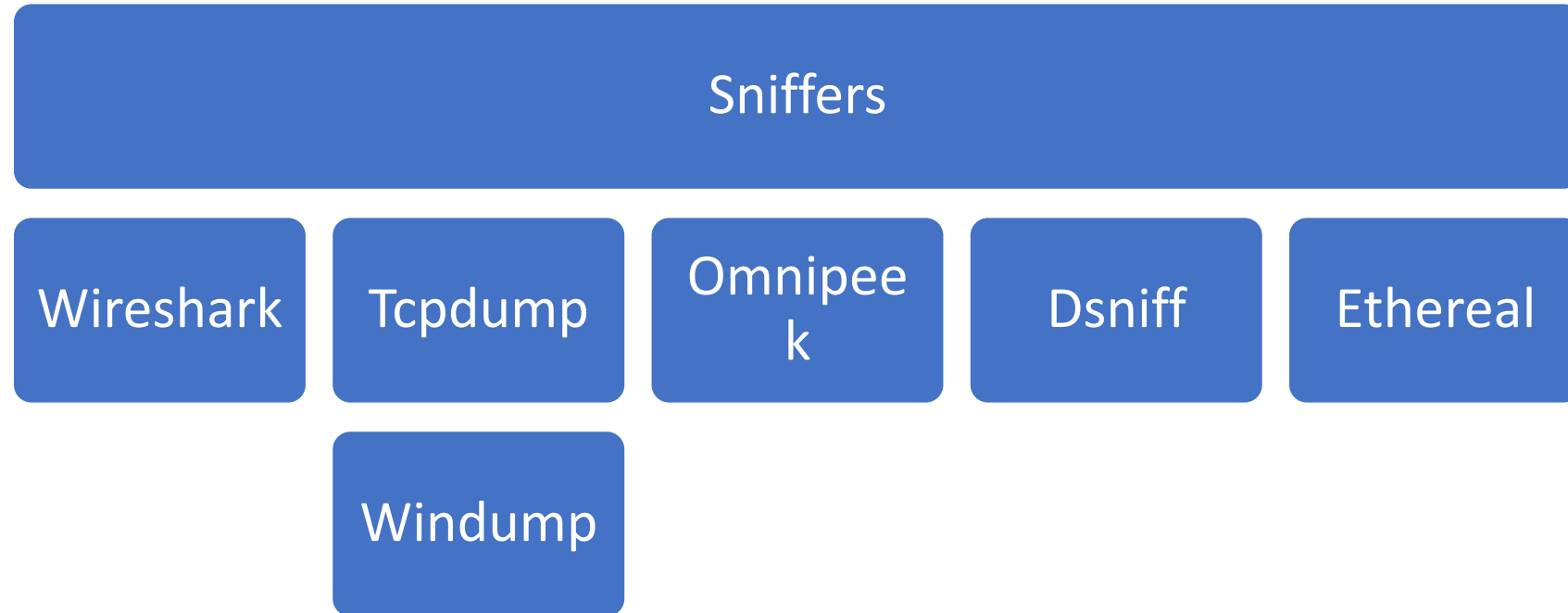
Hardware in the form of network adapters

Drive program or the core sniffing program

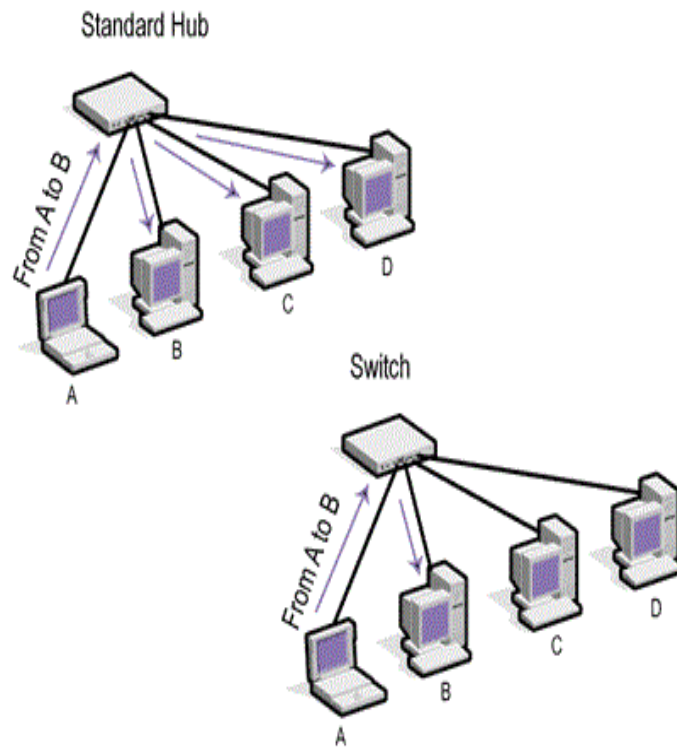
Buffer to temporarily store the results of a sniff

Packet analysis capability to interpret results

A Selection of Sniffing Tools



Types of Sniffing



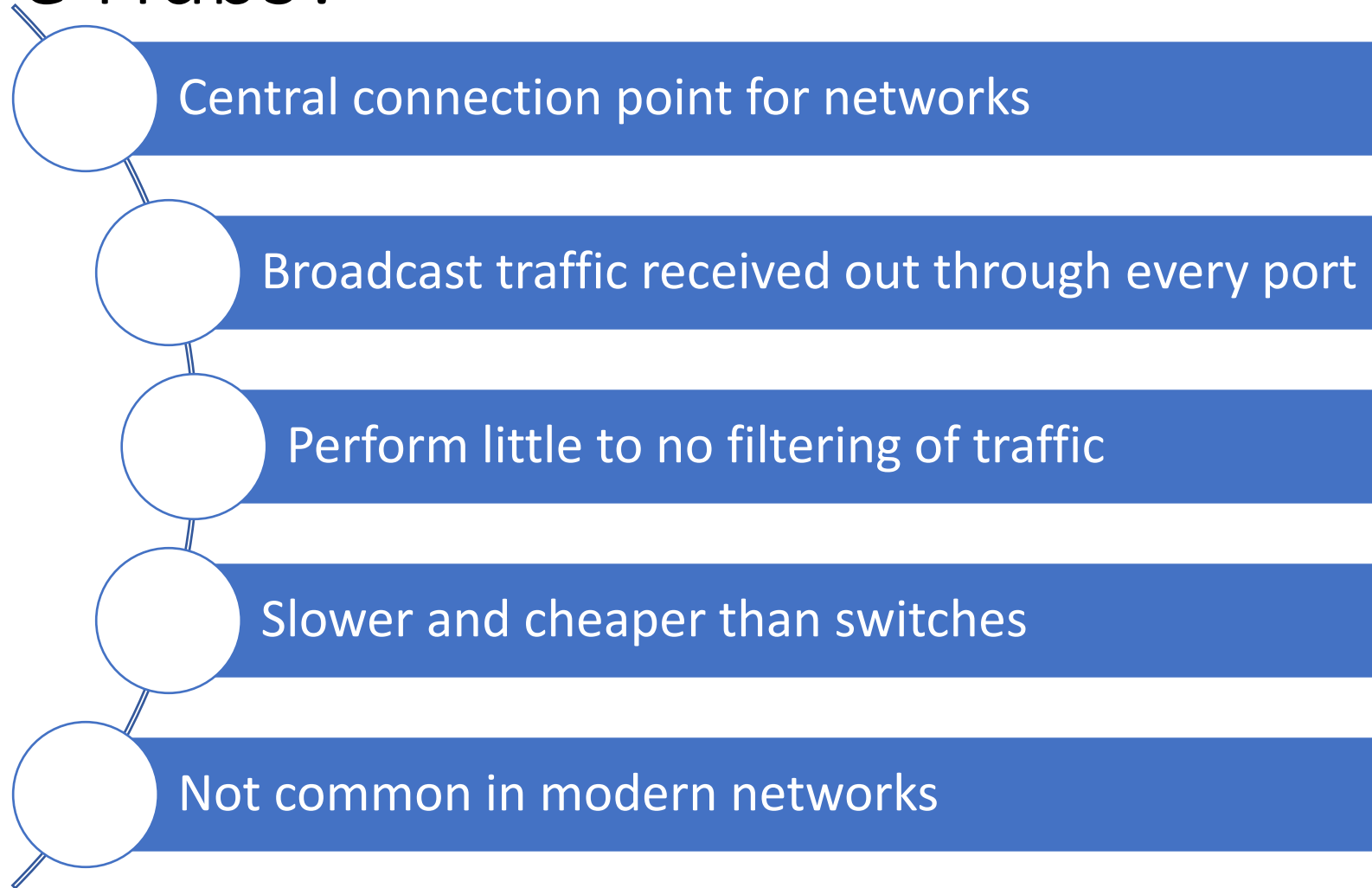
Passive Sniffing

- Sniffing when a hub is present
- Restricted to a network segment
- Tends to be stealthier

Active Sniffing

- Sniffing when a switch is present
- Attempts to bypass switch
- Less stealthy

What Are Hubs?



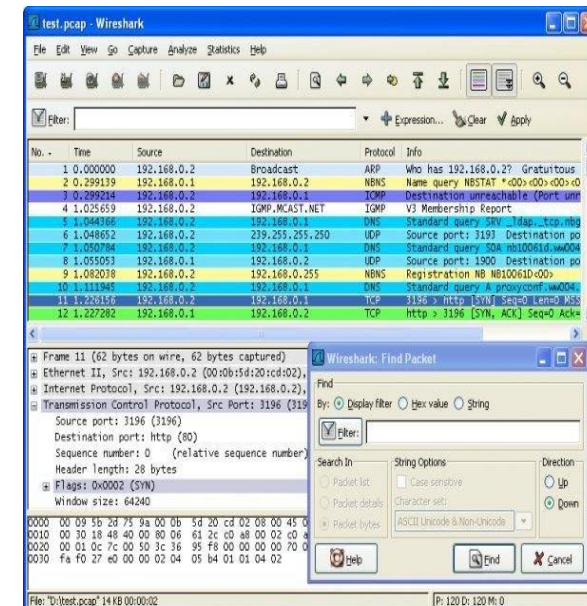
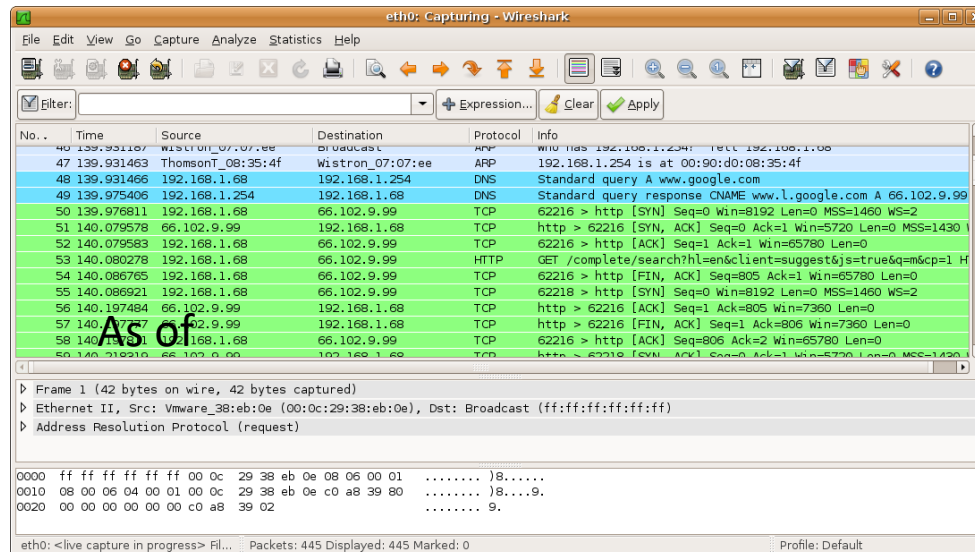
Network Switches

- Switches
 - Perform examination of each packet
 - Look at source and destination of each packet
 - Use information to direct traffic
 - Separate network into collision domains
 - Isolate network nodes from one another

When a packet is received by the switch, the destination and source addresses are compared to a table of network segments and addresses.

Wireshark

- As of this writing, Wireshark reigns supreme as perhaps the best sniffer on the market.
- Wireshark has been around for quite a while, and it has proven its worth time and time again.
- Wireshark is natively available on Windows, Mac OS X, and Linux.



tcpdump

tcpdump is an open source network utility that is freely available under the BSD license.

```
19:28:19.879826 IP localhost.49167 > localhost.50365: Flags [R.], seq 0, ack 3166017868, win 0, length 0
19:28:19.879920 IP localhost.51898 > localhost.iprop: Flags [S], seq 3248656569, win 32792, options [mss 16396,sackOK,TS val 42916125 ecr 0,nop,w
scale 4], length 0
19:28:19.879940 IP localhost.iprop > localhost.51898: Flags [R.], seq 0, ack 3248656570, win 0, length 0
19:28:19.880053 IP localhost.44874 > localhost.4000: Flags [S], seq 1794944033, win 32792, options [mss 16396,sackOK,TS val 42916125 ecr 0,nop,w
scale 4], length 0
19:28:19.880085 IP localhost.4000 > localhost.44874: Flags [R.], seq 0, ack 1794944034, win 0, length 0
19:28:19.880175 IP localhost.56678 > localhost.1061: Flags [S], seq 2568970796, win 32792, options [mss 16396,sackOK,TS val 42916125 ecr 0,nop,w
scale 4], length 0
19:28:19.880199 IP localhost.1061 > localhost.56678: Flags [R.], seq 0, ack 2568970797, win 0, length 0
19:28:19.880281 IP localhost.40931 > localhost.2381: Flags [S], seq 969623656, win 32792, options [mss 16396,sackOK,TS val 42916125 ecr 0,nop,w
scale 4], length 0
19:28:19.886184 IP localhost.45237 > localhost.daap: Flags [S], seq 3948562685, win 32792, options [mss 16396,sackOK,TS val 42916126 ecr 0,nop,w
scale 4], length 0
19:28:19.886238 IP localhost.daap > localhost.45237: Flags [R.], seq 0, ack 3948562686, win 0, length 0
19:28:19.886611 IP localhost.60445 > localhost.2180: Flags [S], seq 3276970595, win 32792, options [mss 16396,sackOK,TS val 42916126 ecr 0,nop,w
scale 4], length 0
19:28:19.886640 IP localhost.2180 > localhost.60445: Flags [R.], seq 0, ack 3276970596, win 0, length 0
19:28:19.886704 IP localhost.33287 > localhost.5001: Flags [S], seq 3351553321, win 32792, options [mss 16396,sackOK,TS val 42916126 ecr 0,nop,w
scale 4], length 0
19:28:19.886721 IP localhost.5001 > localhost.33287: Flags [R.], seq 0, ack 3351553322, win 0, length 0
19:28:19.886774 IP localhost.56540 > localhost.gnutella-svc: Flags [S], seq 1461951535, win 32792, options [mss 16396,sackOK,TS val 42916126 ecr
0,nop,wscale 4], length 0
19:28:19.886790 IP localhost.gnutella-svc > localhost.56540: Flags [R.], seq 0, ack 1461951536, win 0, length 0
19:28:19.886843 IP localhost.55094 > localhost.3369: Flags [S], seq 3248457149, win 32792, options [mss 16396,sackOK,TS val 42916126 ecr 0,nop,w
scale 4], length 0
19:28:19.886850 IP localhost.3369 > localhost.55094: Flags [R.], seq 0, ack 3248457150, win 0, length 0
19:28:19.887040 IP localhost.33350 > localhost.7778: Flags [S], seq 1873935228, win 32792, options [mss 16396,sackOK,TS val 42916126 ecr 0,nop,w
scale 4], length 0
19:28:19.887081 IP localhost.7778 > localhost.33350: Flags [R.], seq 0, ack 1873935229, win 0, length 0
19:28:19.887201 IP localhost.49066 > localhost.49400: Flags [S], seq 3402480467, win 32792, options [mss 16396,sackOK,TS val 42916126 ecr 0,nop,w
scale 4], length 0
19:28:19.887225 IP localhost.49400 > localhost.49066: Flags [R.], seq 0, ack 3402480468, win 0, length 0
19:28:19.887303 IP localhost.55132 > localhost.497: Flags [S], seq 3587565994, win 32792, options [mss 16396,sackOK,TS val 42916126 ecr 0,nop,w
scale 4], length 0
19:28:19.887326 IP localhost.497 > localhost.55132: Flags [R.], seq 0, ack 3587565995, win 0, length 0

minivixante || 0-$ bash 1$ bash 2*$bash || 08-13 19:28
```

A command-line packet sniffer

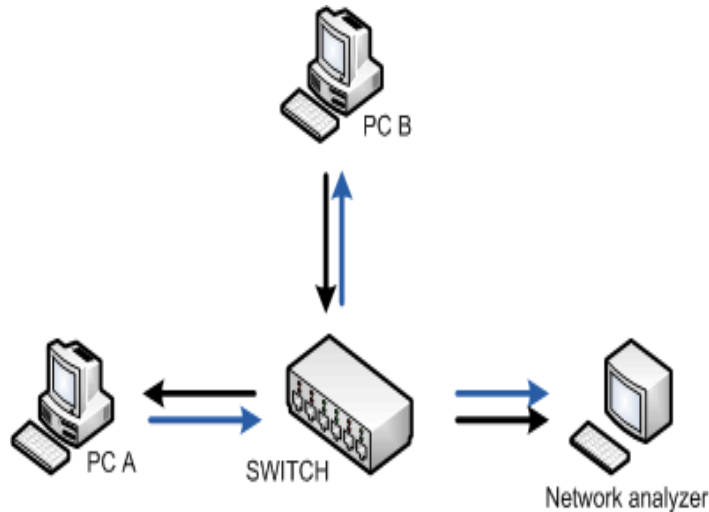
Intercepts traffic in TCP/IP format

Can send output to file

Known as being very fast and efficient

Active Sniffing Close-Up

When sniffing is performed in a switched network, it is called active sniffing.



Active sniffing means the network has a switch instead of a hub.

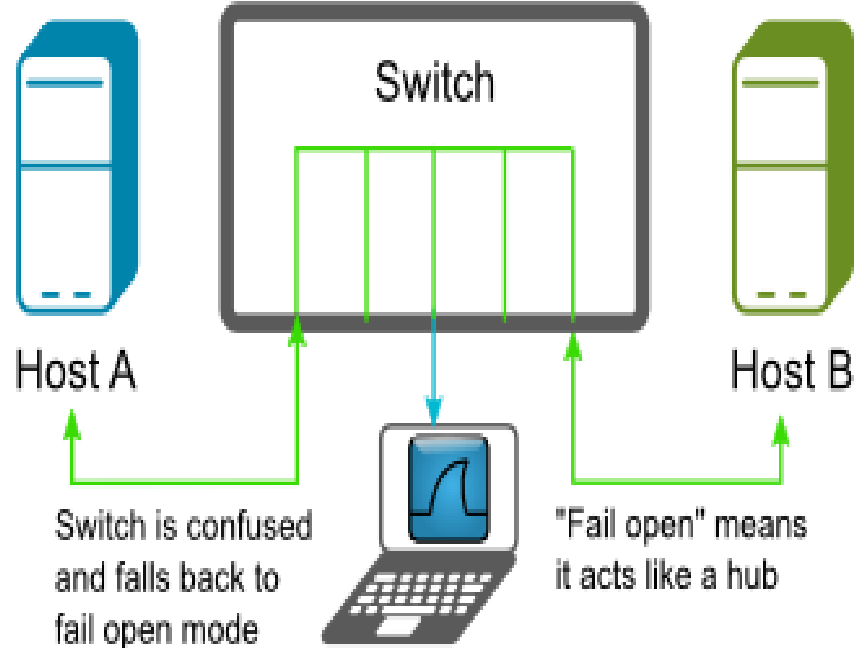
The switch actively regulates traffic.

The switch uses Address Resolution Protocol (ARP) to direct traffic.

The switch maintains an ARP table in memory to track MAC addresses.

MAC Flooding

A switch keeps track of MAC addresses received by writing them to a content addressable memory (CAM) table. If a switch is flooded with MAC addresses, it may easily overwhelm the switch's ability to write to its own CAM table.

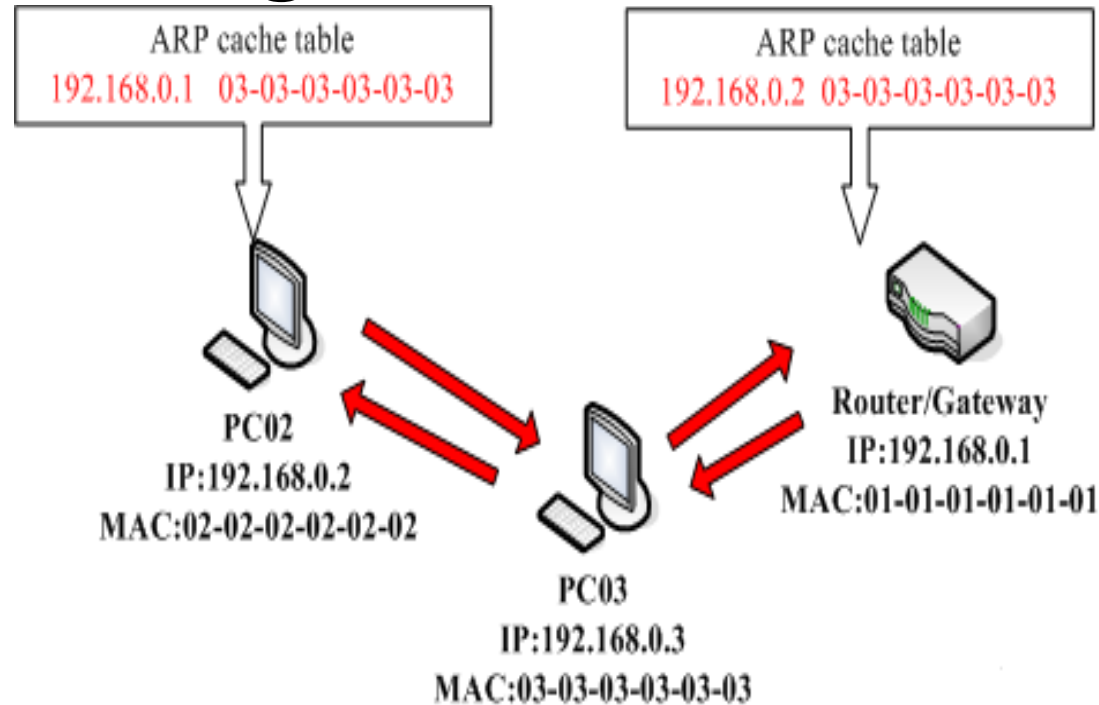


Involves flooding the switch with numerous requests

Overloads the CAM table in the switch

Causes switch to fail and act like a hub

ARP Spoofing



Denial of service

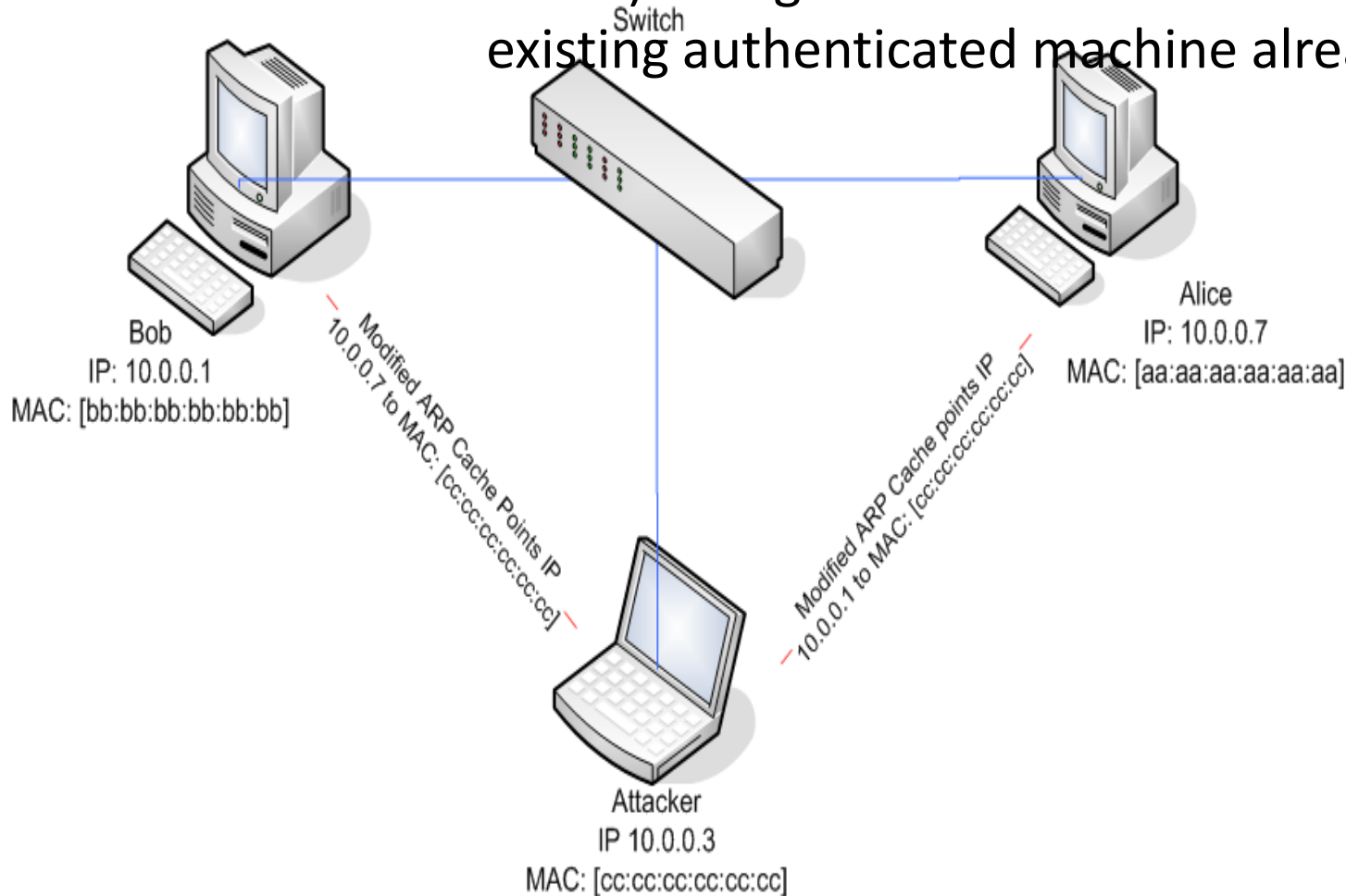
Man-in-the-middle/sniffing

MAC flooding

The ARP protocol is a simple and efficient protocol, but one drawback is its lack of authentication, and as a result, there is no way to verify the IP to MAC address mapping.

MAC Spoofing

MAC spoofing is a simple concept in which an attacker (or pen tester) changes their MAC address to the MAC address of an existing authenticated machine already on the network.

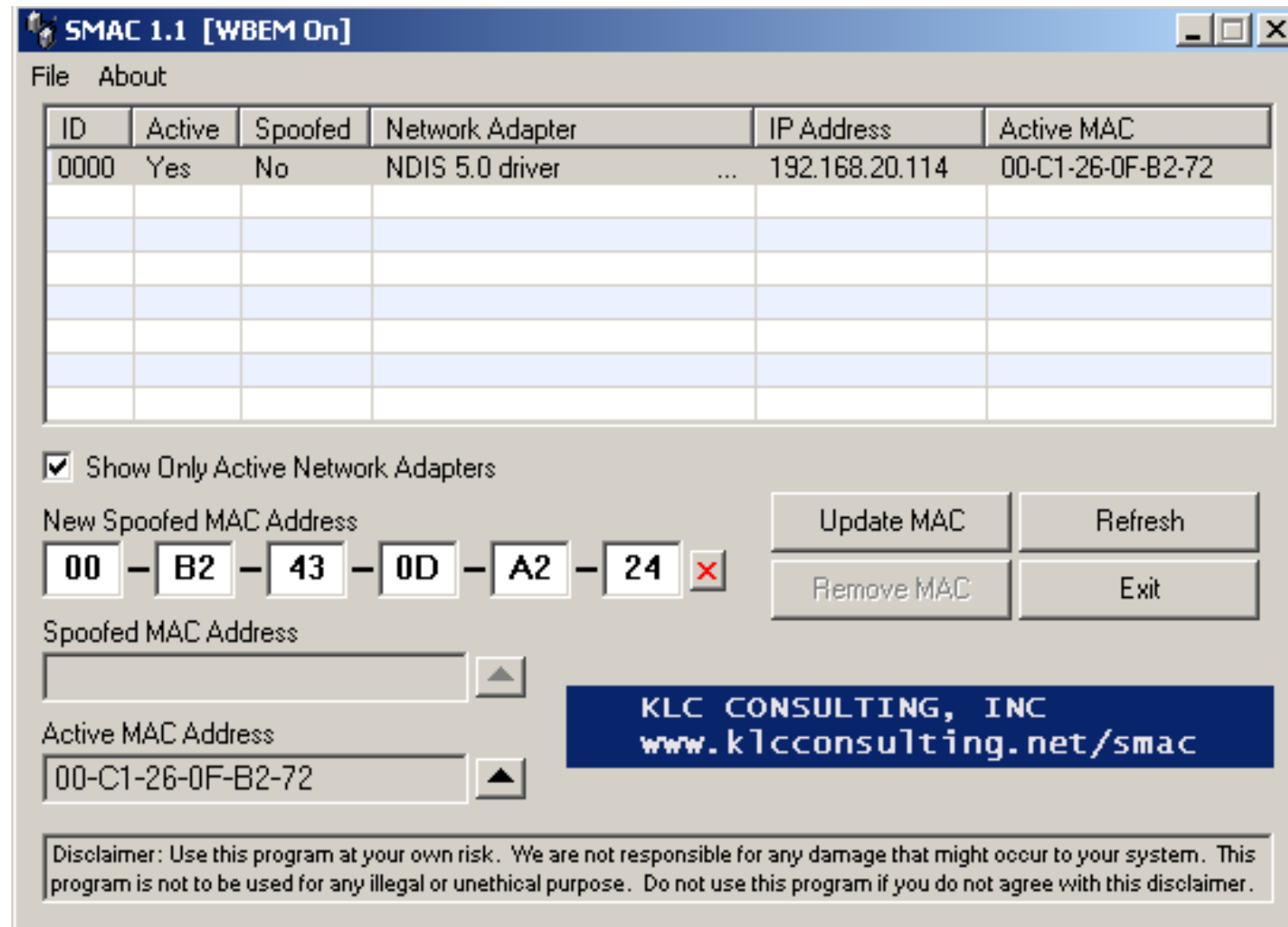


Fakes the MAC address of an existing client

Allows a system to impersonate another

Can allow for the bypass of any mechanism that uses a MAC address to control traffic

SMAC



Sniffing Countermeasures

Use a hardware-switched network for the most sensitive portions of your network.

Implement IP DHCP snooping on switches to prevent ARP poisoning and spoofing attacks.

Implement policies preventing promiscuous mode on network adapters.

Be careful when deploying wireless access points, knowing that all traffic on the wireless network is subject to sniffing.

Encrypt your sensitive traffic using an encrypting protocol such as SSH or IPsec.

Thank You